

DESCARGO DE RESPONSABILIDAD:

Al concluir el curso o programa para el cual se ha proporcionado este documento, se exige de manera imperativa eliminar todas las copias del mismo, incluidas las versiones electrónicas y en papel, para evitar el uso no autorizado o la divulgación no deseada de su contenido. La no eliminación de este documento puede resultar en violaciones de derechos de autor, confidencialidad y privacidad, así como en la posible exposición de información sensible o privilegiada.

La retención no autorizada de este documento también podría dar lugar a consecuencias legales y sanciones, incluidas multas y acciones legales. Al eliminar todas las copias de este documento al concluir el curso o programa, se garantiza la seguridad y confidencialidad de la información contenida en el mismo, así como el cumplimiento de las políticas y regulaciones internas y externas relacionadas con la privacidad y la protección de datos. Además, se promueve la integridad académica y profesional al prevenir el uso indebido o la apropiación indebida de materiales educativos y de referencia.

Se insta a todos los destinatarios de este documento a tomar las medidas necesarias para garantizar su eliminación completa y segura, incluida la destrucción de versiones electrónicas mediante el borrado seguro de archivos y la destrucción física de copias en papel mediante métodos seguros de eliminación, como la trituración o incineración.

Compliance360 Executive Education no asume ninguna responsabilidad por cualquier consecuencia derivada de la retención no autorizada o el uso indebido de este documento una vez concluido el curso o programa para el cual fue proporcionado. Se espera y se confía en que todos los destinatarios actúen de manera responsable y cumplan con esta exigencia de eliminación para proteger la confidencialidad, integridad y seguridad de la información contenida en este documento.

DESCARGO DE RESPONSABILIDAD:

La traducción del presente documento no es oficial y ha sido realizada por Compliance360 Executive Education mediante el uso de herramientas de traducción automatizada como Google Translate y el Diccionario de Cambridge. Aunque hemos realizado esfuerzos para garantizar la precisión y la coherencia en la traducción, no podemos garantizar la exactitud completa ni la fidelidad al texto original.

Este documento se proporciona únicamente con fines educativos y de referencia. No debe considerarse como una traducción oficial ni utilizarse como sustituto de asesoramiento profesional o legal.

Además, se requiere que este documento sea utilizado exclusivamente con fines educativos y formativos, y se prohíbe su uso para cualquier otro propósito. Al concluir el curso o programa para el cual se ha proporcionado este documento, se solicita eliminar todas las copias del mismo, incluidas las versiones electrónicas y en papel, para evitar el uso no autorizado o la divulgación no deseada de su contenido.

Compliance360 Executive Education y los traductores involucrados en la realización de esta traducción no asumen ninguna responsabilidad por cualquier error, omisión, pérdida o daño que pueda surgir directa o indirectamente del uso de este documento.

Al aceptar y utilizar este documento, usted reconoce haber leído, comprendido y aceptado los términos de este descargo de responsabilidad.

TÉCNICO ESPECIFICACIÓN

ISO/TS
37008

Primera edición
2023-07

Investigaciones internas de organizaciones: orientación

Enquêtes internes des Organizations — Recomendaciones



Comparta sus comentarios sobre el estándar.
Escanea el código QR
con tu teléfono o haz clic en el enlace
[Formulario de comentarios del cliente](#)



Número de referencia
ISO/TS 37008:2023(E)

ISO/TS 37008:2023(E)



DOCUMENTO PROTEGIDO POR DERECHOS DE AUTOR

© ISO 2023

Reservados todos los derechos. A menos que se especifique lo contrario o se requiera en el contexto de su implementación, ninguna parte de esta publicación puede reproducirse o utilizarse de otra manera de ninguna forma o por ningún medio, electrónico o mecánico, incluida la fotocopia, o la publicación en Internet o una intranet, sin previa autorización. permiso escrito. El permiso se puede solicitar a ISO en la dirección que figura a continuación o al organismo miembro de ISO en el país del solicitante.

Oficina de derechos de
autor ISO CP 401 • Cap. de Blandonnet

8 CH-1214 Vernier, Ginebra
Teléfono: +41 22 749 01 11

Correo electrónico:
copyright@iso.org Sitio web: www.iso.org

Publicado en Suiza

Contenido

Página

Prefacio.....v

Introducción..... vi

1 Alcance.....1

2 Referencias normativas1

3 Términos y definiciones.....1

4 Principios.....3

4.1 Independiente..... 3

4.2Confidencial..... 3

4.3 Competente y profesional..... 3

4.4 Objetivo e imparcial..... 3

4.5 Legal y lícito..... 3

5 Apoyo a investigaciones internas.....3

5.1 Recursos 3

5.2 Liderazgo y compromiso..... 4

6 Establecimiento de una política o procedimiento de investigación.....4

7 Medidas de seguridad y protección4

7.1 Preservar y asegurar pruebas..... 4

7.2 Protección y apoyo al personal involucrado en las investigaciones..... 5

7.3 Antirrepresalias 5

7.4 Salvaguardia 5

8 Proceso de investigación5

8.1 Equipo de investigación 5

8.1.1 Designación del equipo de investigación..... 5

8.1.2 Línea jerárquica de investigación 5

8.2 Evaluación preliminar..... 6

8.3 Determinación del alcance de la investigación 6

8.3.1 Alcance..... 6

8.3.2 Cambios de alcance..... 6

8.3.3 Elementos de determinación..... 6

8.4 Planificación de la investigación 7

8.5 Mantener la confidencialidad..... 7

8.6 Advertencia de responsabilidad para disuadir la divulgación 8

8.6.1 Aviso de precaución por escrito 8

8.6.2 Aviso de precaución verbal 8

8.7 Sin interferencias..... 8

8.8 Pruebas 8

8.8.1 Recopilación y revisión de documentos..... 8

8.8.2 Recopilación, preservación, análisis y revisión de datos electrónicos..... 8

8.9 Entrevistas..... 9

8.9.1 Preparativos..... 9

8.9.2 Realización de una entrevista..... 9

8.9.3 Mantener registros de una entrevista..... 10

8.10 Proceso de finalización..... 10

8.11 Informe de investigación..... 10

9 Posibles medidas correctivas o mejoras.....10

9.1 Propuesta de medidas correctivas y mejoras 10

9.2 Medidas correctivas provisionales.....11

9.3 Un plan final para medidas correctivas posteriores a la investigación11

9.4 Proporcionalidad de las medidas de remediación y mejora11

9.5 Monitoreo y aplicación de medidas correctivas11

ISO/TS 37008:2023(E)

10	Interacción con las partes interesadas	11
	10.1 Generalidades.....	11
	10.2 Planificación.....	11
	10.3 Medidas para el proceso de comunicación.....	12 10.4
	Canales de comunicación efectivos	12 10.5
	Comunicación entre el gobierno y los reguladores.....	12 10.6
	Autodivulgación a las autoridades.....	12
11	Acciones disciplinarias	12
Anexo A (informativo) Orientación sobre el uso de este documento.		13
Bibliografía.....		24

Prefacio

ISO (la Organización Internacional de Normalización) es una federación mundial de organismos nacionales de normalización (organismos miembros de ISO). El trabajo de preparación de Normas Internacionales normalmente se lleva a cabo a través de comités técnicos de ISO. Cada organismo miembro interesado en un tema para el cual se ha establecido un comité técnico tiene derecho a estar representado en ese comité. En el trabajo también participan organizaciones internacionales, gubernamentales y no gubernamentales, en colaboración con ISO.

ISO colabora estrechamente con la Comisión Electrotécnica Internacional (IEC) en todos los asuntos de normalización electrotécnica.

Los procedimientos utilizados para desarrollar este documento y aquellos destinados a su mantenimiento posterior se describen en las Directivas ISO/IEC, Parte 1. En particular, se deben tener en cuenta los diferentes criterios de aprobación necesarios para los diferentes tipos de documentos ISO. Este documento fue redactado de acuerdo con las reglas editoriales de las Directivas ISO/IEC, Parte 2 (ver www.iso.org/directives).

Se llama la atención sobre la posibilidad de que algunos de los elementos de este documento puedan ser objeto de derechos de patente. ISO no será responsable de identificar cualquiera o todos estos derechos de patente. Los detalles de cualquier derecho de patente identificado durante el desarrollo del documento estarán en la Introducción y/o en la lista ISO de declaraciones de patente recibidas (ver www.iso.org/patents).

Cualquier nombre comercial utilizado en este documento es información proporcionada para comodidad de los usuarios y no constituye un respaldo.

Para obtener una explicación de la naturaleza voluntaria de las normas, el significado de los términos y expresiones específicos de ISO relacionados con la evaluación de la conformidad, así como información sobre la adhesión de ISO a los principios de la Organización Mundial del Comercio (OMC) en las Obstáculos Técnicos al Comercio (OTC), consulte www.iso.org/iso/foreword.html.

Este documento fue preparado por el Comité Técnico ISO/TC 309, Gobernanza de las organizaciones.

Cualquier comentario o pregunta sobre este documento debe dirigirse al organismo de normalización nacional del usuario. Puede encontrar una lista completa de estos organismos en www.iso.org/members.html.

ISO/TS 37008:2023(E)

Introducción

La investigación interna es una parte integral de la gestión organizacional. La investigación interna es un proceso profesional de investigación de hechos, iniciado por o para una organización, para establecer hechos en relación con presuntas o sospechas de irregularidades, mala conducta o incumplimiento (como sobornos, actividades fraudulentas, acoso, violencia o discriminación). Las investigaciones internas permiten a una organización:

- tomar decisiones informadas si se han violado leyes, regulaciones, códigos industriales, políticas internas, procedimientos, procesos, políticas de cumplimiento corporativo y/o los valores y la ética de la organización;
- comprender la(s) causa(s) que llevaron a los incumplimientos antes mencionados;
- determinar si una acusación o preocupación está fundamentada o no;
- evaluar la pérdida financiera de una organización;
- mitigar la responsabilidad de la organización y/o su dirección;
- establecer y aplicar las medidas de mitigación necesarias para evitar que se produzcan conductas similares ocurriendo;
- fortalecer la cultura de cumplimiento y ética de la organización;
- presentar informes externos a las autoridades pertinentes (cumplimiento de la ley, órganos judiciales, reguladores u otros órganos prescritos por la ley o reglamento) o partes interesadas relevantes cuando sea necesario;
- tomar decisiones sobre sanciones a la dirección y/o empleados y la prohibición de trabajar con terceros involucrados en conductas poco éticas.

Las acciones civiles, los informes de denunciantes y las investigaciones externas por parte de los reguladores también pueden ser motivos para una investigación interna, de modo que las organizaciones interesadas puedan descubrir qué desencadenó las acciones, informes e investigaciones externas y luego tomar las medidas adecuadas.

La investigación interna es parte de un sistema de gestión del cumplimiento. Este documento se puede utilizar para ayudar con la implementación de otras normas como ISO 37301, ISO 37001 e ISO 37002. También puede ser una herramienta útil para que una organización identifique riesgos. Con el riesgo claramente identificado, una organización puede analizar las causas fundamentales del incumplimiento y diseñar medidas para controlar los riesgos.

No tener las capacidades para realizar investigaciones internas y/o no realizar investigaciones internas puede tener efectos adversos en una organización, como comprometer la eficacia del sistema de gestión del cumplimiento, no proteger su reputación y no detectar y contrarrestar las irregularidades.

Este documento proporciona orientación para que las organizaciones implementen investigaciones internas basadas en los siguientes principios: independiente, confidencial, competente y profesional, objetiva e imparcial, y legal y legal.

[La Figura 1](#) es una descripción general conceptual del proceso de investigación que muestra el panorama completo de la investigación interna y las posibles acciones posteriores a la investigación.

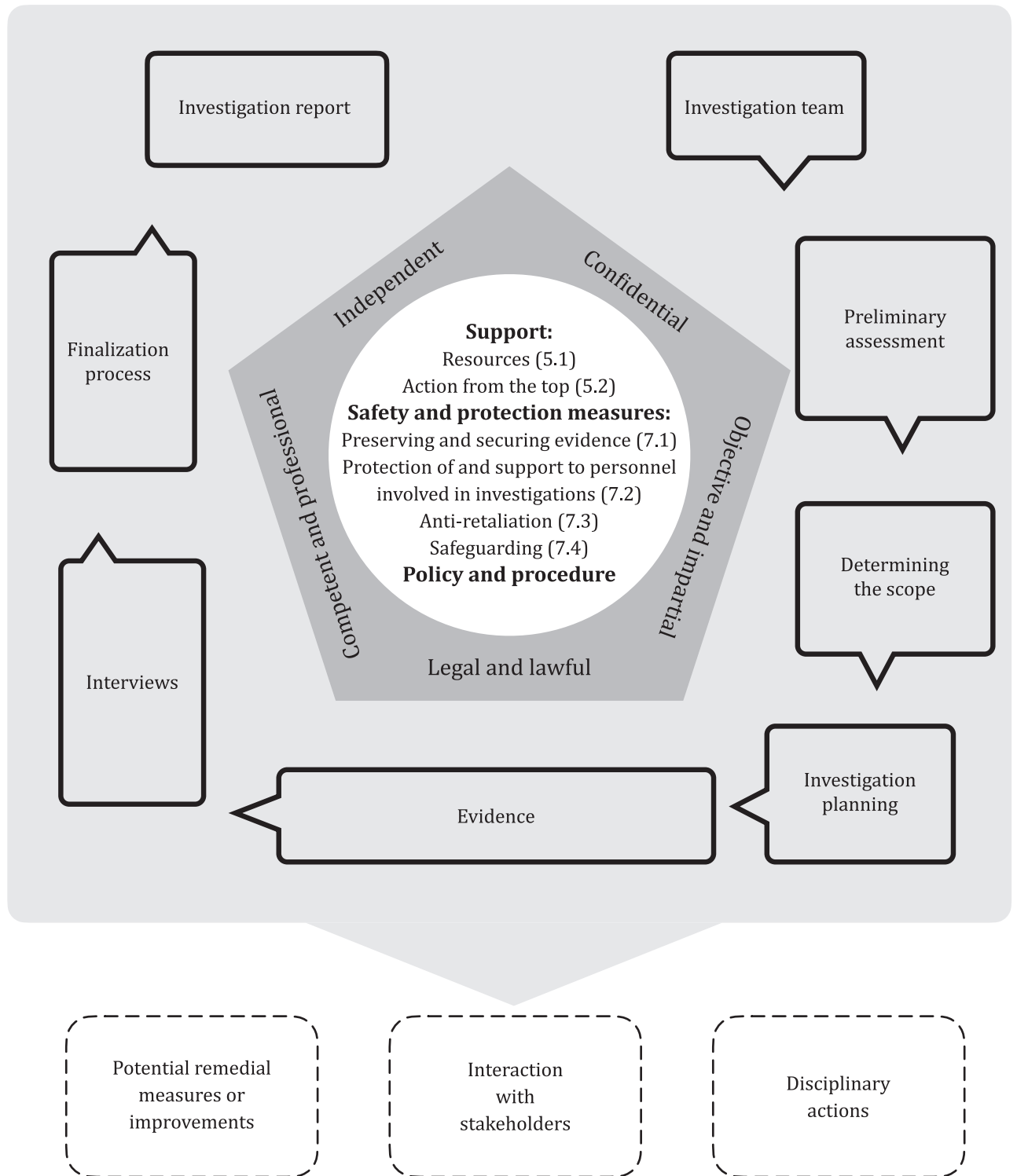


Figure 1 — Overview of the investigative process

Investigaciones internas de organizaciones: orientación

1 Alcance

Este documento brinda orientación sobre investigaciones internas dentro de las organizaciones, que incluyen:

- los principios;
- apoyo a las investigaciones;
- establecimiento de la política, los procedimientos, los procesos y las normas para llevar a cabo e informar sobre una investigación;
- la comunicación de los resultados de la investigación;
- la aplicación de medidas correctoras.

Este documento es aplicable a todas las organizaciones independientemente de su tipo, tamaño, ubicación, estructura o propósito.

NOTA Consulte el [Anexo A](#) para obtener orientación sobre el uso de este documento.

2 Referencias normativas

Los siguientes documentos se mencionan en el texto de tal manera que parte o todo su contenido constituye requisitos de este documento. Para las referencias con fecha, sólo se aplica la edición citada. Para referencias sin fecha, se aplica la última edición del documento de referencia (incluidas las modificaciones).

ISO 37001, Sistemas de gestión antisoborno. Requisitos con orientación para su uso.

ISO 37002, Sistemas de gestión de denuncias de irregularidades. Directrices

ISO 37301, Sistemas de gestión del cumplimiento. Requisitos con orientación para su uso.

3 Términos y definiciones

A los efectos de este documento, se aplican los términos y definiciones dados en ISO 37001, ISO 37002, ISO 37301 y siguientes.

ISO e IEC mantienen bases de datos terminológicas para su uso en la estandarización en las siguientes direcciones:

— Plataforma de navegación ISO Online: disponible en <https://www.iso.org/obp>

— Electropedia IEC: disponible en <https://www.electropedia.org/>

3.1

proceso profesional de

investigación interna de investigación, iniciado por o para una organización (3.3), para establecer hechos en relación con presuntas o sospechas de irregularidades, mala conducta o incumplimiento

3.2

efecto

riesgo de la incertidumbre sobre los objetivos

[FUENTE: ISO 31000:2018, 3.1, modificada - Notas de entrada eliminadas.]

ISO/TS 37008:2023(E)

3.3

organización

persona o grupo de personas que tiene funciones propias con responsabilidades, autoridades y relaciones para lograr sus objetivos

Nota 1 a la entrada: El concepto de organización incluye, entre otros, comerciante individual, compañía, corporación, empresa, autoridad, sociedad, organización benéfica o institución, o parte o combinación de las mismas, ya sea constituida o no, pública o privado.

[FUENTE: ISO 37301:2021, 3.1, modificada — Nota 2 a la entrada eliminada.]

3.4

necesidad de saber

requisito legítimo de conocer o tener acceso a una cantidad mínima de información sensible

[FUENTE: ISO 19650-5:2020, 3.4, modificada: “de un posible destinatario de información” eliminado, “o tener acceso a” reemplazado por “acceder o poseer” y “una cantidad mínima de” agregado a la definición.]

3.5

investigador (es)

designado(s) para gestionar o llevar a cabo una investigación

3.6

investigador principal

persona que dirige una investigación

3.7

parte interesada

persona u organización (3.3) que puede afectar, verse afectada o percibirse a sí misma como afectada por una decisión o actividad

[FUENTE: ISO 37301:2021, 3.2, modificada: “parte interesada” eliminada como término preferido.]

3.8

Persona(s) de la función de investigación

interna con la responsabilidad organizacional de las investigaciones.

3.9

persona o grupo de personas

con función de cumplimiento con responsabilidad y autoridad para la operación del sistema de gestión de cumplimiento

[FUENTE: ISO 37301:2021, 3.23, modificada — Nota 1 a la entrada eliminada.]

3.10

órgano de gobierno

persona o grupo de personas que tiene la responsabilidad y autoridad última sobre las actividades, el gobierno y las políticas de una organización (3.3) y ante el cual la alta dirección (3.11) informa y por el cual la alta dirección debe rendir cuentas

[FUENTE: ISO 37301:2021, 3.21, modificada - Notas de entrada eliminadas.]

3.11

alta dirección persona o

grupo de personas que dirige y controla una organización (3.3) al más alto nivel

[FUENTE: ISO 37301:2021, 3.3, modificada - Notas de entrada eliminadas.]

4 principios

4.1 Independiente

Una investigación interna no debe ser influenciada ni controlada por otras personas, eventos o incentivos en relación con el tema que se investiga.

NOTA Consulte [A.3.1](#) como orientación.

4.2Confidencial

Todos los documentos e información recopilados en el contexto de una investigación, incluidos registros, pruebas e informes, deben tratarse de manera confidencial y sensible. Los documentos y la información sólo deben revelarse cuando sea necesario y los investigadores deben conocer las leyes y requisitos reglamentarios aplicables.

4.3 Competente y profesional

Una investigación interna debe ser realizada por investigadores que tengan habilidades, conocimientos, experiencia, actitud y capacidad profesionales para garantizar la calidad de su trabajo.

Una investigación interna debe realizarse con integridad, equidad, veracidad, tenacidad, confianza, inteligencia emocional, buen juicio y diligencia, y completarse de manera oportuna.

NOTA Consulte [A.3.2](#) como orientación.

4.4 Objetivo e imparcial

Una investigación interna debe estar libre de conflictos de intereses, realizarse objetivamente y basarse en pruebas fácticas. La investigación no debe verse influenciada por sentimientos, interpretaciones o prejuicios personales.

NOTA Consulte [A.3.3](#) como orientación.

4.5 Legal y legal

Quienes establezcan o realicen una investigación interna deben identificar las regulaciones, los estatutos y la legislación aplicables en todas las jurisdicciones aplicables para garantizar la legalidad de la investigación.

NOTA Consulte [A.3.4](#) como orientación.

5 Apoyo a las investigaciones internas

5.1 Recursos

El órgano de gobierno debe apoyar el establecimiento, implementación, mantenimiento y mejora continua de las investigaciones internas, para lo cual la alta dirección de la organización debe proporcionar recursos adecuados.

Los recursos pueden incluir, entre otros, personal, infraestructura financiera, técnica y organizacional. Estos recursos pueden proporcionarse interna o externamente.

NOTA Consulte [A.4.1](#) para obtener más información.

ISO/TS 37008:2023(E)

5.2 Liderazgo y compromiso

El órgano de gobierno, la alta dirección y otras personas en los puestos apropiados deben demostrar liderazgo y compromiso con una investigación interna independiente, objetiva, imparcial y confidencial.

El órgano de gobierno, la alta dirección y otras personas en los cargos apropiados deben ser informados razonablemente, de acuerdo con el plan de comunicación acordado, los lineamientos y políticas internas preestablecidas, o según lo consideren necesario los investigadores.

NOTA Consulte [A.4.2](#) como orientación.

6 Establecimiento de una política o procedimiento de investigación

La organización debería establecer e implementar una política o procedimientos de investigación que:

- definir el alcance, el proceso, las responsabilidades y las capacidades de la investigación de los investigadores internos;
- establecer un vínculo claro con los procedimientos de “denuncia” o “denuncia” de la organización;
- exigir medidas oportunas y apropiadas cada vez que surja una inquietud;
- garantizar que la investigación se lleve a cabo respetando los derechos de las personas involucradas;
- facultar y permitir a los investigadores realizar trabajos de investigación;
- exigir la cooperación de todo el personal en la investigación;
- garantizar que la investigación sea llevada a cabo por personal independiente del investigación;
- exigir que los resultados de la investigación, incluidas cualquier limitación, desafío o cualquier otra preocupación de la investigación, se documenten, revisen y notifiquen adecuadamente;
- exigir que la investigación se lleve a cabo de forma confidencial y que la información solo se comparta con personas quién necesita saber;
- exigir que la organización cuente con políticas o procesos establecidos para detener acciones ilegales inmediatamente, también durante una investigación en curso;
- exigir que las lecciones aprendidas o las recomendaciones que surjan de las investigaciones se utilicen para evitar que se repitan las irregularidades;
- exigir que las políticas y procedimientos se actualicen periódicamente con el aprendizaje de las autoridades internas. investigaciones.

NOTA Consulte [la Cláusula A.5](#) como orientación.

7 Medidas de seguridad y protección

7.1 Preservación y protección de pruebas

Desde el comienzo del proceso, los investigadores deben comenzar a identificar dónde se pueden almacenar las pruebas pertinentes.

Un investigador debe trabajar con las funciones relevantes de la organización para establecer si algún testigo clave o personal investigado ya está en proceso de abandonar la organización, por cualquier motivo.

La organización debe tener políticas o procesos para evitar que alguien manipule a los testigos y borre, destruya, altere, transfiera u oculte intencionalmente o no.

cualquier forma de información, datos o registros, que puedan ser utilizados como prueba, y someter a la persona a medidas disciplinarias como violación del código de conducta.

La organización también debería establecer medidas de protección para evitar que la información adquirida en el curso de la investigación se entregue a personas sin necesidad de saberla.

NOTA Consulte [A.6.1](#) como orientación.

7.2 Protección y apoyo al personal involucrado en las investigaciones

La organización debería tomar medidas para garantizar que:

- todas las actividades de investigación, incluidas las entrevistas, se lleven a cabo sin ningún tipo de amenaza, promesa, incentivo u opresión;
- las consultas y entrevistas se realicen de manera discreta y con un nivel razonable de privacidad;
- las pruebas aportadas por los testigos se mantienen confidenciales.

NOTA Consulte [A.6.2](#) como orientación.

7.3 Antirrepresalias

La organización debe adoptar medidas para garantizar que los testigos, denunciantes, investigadores, entrevistados, sujetos de investigación y el personal que toma decisiones sobre medidas correctivas y disciplinarias tengan protección contra cualquier forma de presión, intimidación, amenaza, acoso y cualquier otra conducta nociva.

NOTA Consulte [A.6.3](#) como orientación.

7.4 Salvaguardia

La organización debe proteger el bienestar físico y psicológico de cualquiera que participe en la investigación.

8 Proceso de investigación

8.1 Equipo de investigación

8.1.1 Designación del equipo de investigación

La alta dirección o el órgano de gobierno deben nombrar o autorizar a una persona o equipo para realizar una investigación, a menos que un estatuto de investigación existente preestablezca el proceso de nombramiento. En caso de que la dirección actual tenga un conflicto de intereses, la dirección del siguiente nivel deberá realizar dicho nombramiento o autorización. Se puede asignar una investigación a investigadores externos.

NOTA Consulte [A.7.1](#) para obtener más información.

8.1.2 Línea jerárquica de investigación

El órgano de gobierno, la alta dirección u otras personas en el puesto apropiado según las políticas internas de la organización deben designar una línea jerárquica de investigación que será responsable de aplicar sanciones y recomendar acciones de seguimiento adicionales a la investigación.

El equipo de investigación debe mantener actualizada periódicamente o a intervalos definidos la línea jerárquica de la investigación, incluidas las funciones, responsabilidades y autoridades, y presentar el informe de la investigación para su revisión.

ISO/TS 37008:2023(E)

Las responsabilidades de la línea jerárquica de investigación incluyen, entre otras:

- evaluación de la naturaleza de la(s) acusación(es);
- comprobar cualquier posible conflicto de intereses;
- revisar la posibilidad de futuras interacciones con las autoridades y otras partes interesadas en relación con los resultados de la investigación;
- consideración de la gravedad o gravedad del problema;
- evaluación del riesgo financiero, reputacional o regulatorio potencial para la organización.

8.2 Evaluación preliminar

El equipo de investigación debe realizar una evaluación preliminar de la acusación.

El equipo de investigación debe considerar la seriedad y credibilidad de la acusación presentada y si son lo suficientemente específicas como para iniciar una investigación.

Cuando sea posible, el equipo de investigación debe considerar comunicarse con el denunciante y pedirle detalles adicionales en relación con las acusaciones, luego evaluar si es necesaria una investigación a gran escala y utilizar los resultados de la evaluación para planificar la investigación.

Los resultados de la evaluación preliminar deben documentarse claramente. En los casos en que se requieran más investigaciones, esto debe reflejarse en una decisión documentada.

NOTA Consulte [A.7.2](#) para obtener más información.

8.3 Determinación del alcance de la investigación

8.3.1 Alcance

El equipo de investigación debe considerar los resultados de la evaluación preliminar, si los hubiera, para determinar el alcance de la investigación de modo que ésta pueda llevarse a cabo de manera efectiva y adecuada.

Antes de determinar el alcance de la investigación, es importante establecer el objetivo previsto de la investigación, como por ejemplo:

- si se exige al investigador que simplemente descubra los hechos de un incidente concreto;
- si el investigador está obligado a tomar una determinación sobre si existe algún incumplimiento de la política organizacional o una posible violación de la ley;
- si el investigador tiene que hacer una recomendación sobre qué acción se debe tomar en caso de que se identifique una infracción.

8.3.2 Cambios de alcance

Si, como parte de la investigación, el equipo de investigación tiene conocimiento de otras violaciones de la ley, políticas organizativas o actividades delictivas, entonces el alcance de la investigación debe adaptarse en consecuencia. El cambio de alcance debe documentarse.

8.3.3 Elementos de determinación

Al determinar el alcance de la investigación, el equipo de investigación debe considerar elementos críticos, que incluyen, entre otros:

- sustancia: la(s) alegación(es) específica(s);
- intervalo: el período de tiempo que debe examinar la investigación;

- geografía: qué región(es) o país(es) cubrirá la investigación;
- ubicación: donde tuvo lugar cualquier presunto incidente específico;
- personas: que presuntamente cometieron una infracción.

8.4 Planificación de la investigación

El equipo de investigación debe establecer un plan de investigación. El plan debe describir los siguientes factores:

- los antecedentes, el alcance, el cronograma, el propósito y el objetivo de la investigación;
- el personal que debe ser entrevistado o proporcionar información para ayudar en la investigación;
- recursos internos o externos necesarios y disponibles para lograr el objetivo y si se necesitan recursos expertos, como contables forenses, abogados externos, investigadores externos, expertos de la industria o expertos en ciencia forense digital;
- una evaluación de si el contrato laboral de algún empleado o custodio debe suspenderse mientras duren las investigaciones y revocarse el acceso físico a las oficinas o los sistemas informáticos;
- posibles fuentes de pruebas y cómo abordar la preservación, recopilación y revisión de las mismas;
- cómo realizar las entrevistas, incluido el calendario de entrevistas y notificaciones;
- si alguna persona sujeta a la investigación necesita o exige representación legal, si está permitida, y/o una persona de apoyo que le acompañe durante la entrevista;
- si existe alguna cuestión jurídica importante;
- los riesgos y/o desafíos que el tema de la investigación puede causar a la investigación y a la organización, y qué estrategias se utilizarán para mitigarlos o eliminarlos;
- cómo se debe registrar la investigación y a qué partes interesadas se debe informar, cuándo y con qué nivel de detalle;
- si la organización está obligada a hacer una divulgación al gobierno en cuestión
autoridad competente de conformidad con los requisitos de presentación de informes.

El plan de investigación debe tratarse como un documento vivo y debe actualizarse a medida que cambie la situación para garantizar que la investigación cumpla con el alcance, el objetivo y los principios fundamentales. Los cambios al plan de investigación deben documentarse.

NOTA Consulte [A.7.3](#) como orientación.

8.5 Mantener la confidencialidad

El flujo de información debe controlarse según sea necesario y mantenerse confidencial durante todo el proceso de investigación.

Cuando sea necesario, el investigador principal podrá informar a las partes interesadas pertinentes identificadas en el plan de investigación.

NOTA Consulte [A.7.4](#) para obtener más información.

ISO/TS 37008:2023(E)

8.6 Advertencia de responsabilidad para disuadir la divulgación

8.6.1 Aviso de precaución por escrito

Se recomienda emitir un aviso de precaución por escrito a las partes interesadas para resaltar la importancia del requisito de mantener la confidencialidad, los impactos negativos de la divulgación (accidental o de otro tipo) y las posibles responsabilidades por la divulgación.

Los impactos negativos de la divulgación incluyen, entre otros, la manipulación o eliminación de pruebas, causar daño a las personas involucradas en la investigación o causar daños a la organización. Una violación de la confidencialidad puede dar lugar a sanciones y responsabilidad para las personas que causan la violación.

NOTA Consulte [A.7.5](#) como orientación.

8.6.2 Aviso de precaución verbal

En determinadas circunstancias, un aviso de advertencia verbal puede ser más apropiado que un aviso de advertencia escrito dirigido a las partes interesadas. El investigador principal debe decidir cuándo y cómo comunicarlo. Un aviso de precaución verbal debe incluir los aspectos principales establecidos en el aviso de precaución escrito. El investigador principal debe mantener un registro de cualquier advertencia verbal emitida y puede informar a las partes interesadas de este registro.

La precaución debe incluir aconsejar a la persona que no haga nada que pueda interferir con el proceso de investigación o impedir la recopilación de hechos.

8.7 Sin interferencias

La organización debería tomar medidas para evitar o detener la interferencia en la investigación. Esto puede incluir interferencia de partes externas, otras organizaciones y partes internas, como cierta gerencia u otros departamentos. El investigador principal debe informar cualquier intento relevante de interferir en la investigación a la línea jerárquica de la investigación o a la dirección de la organización de acuerdo con la política o el procedimiento de investigación, o en la forma que el investigador principal considere apropiada.

8.8 Evidencia

8.8.1 Recopilación y revisión de documentos

El equipo de investigación debe tomar todas las medidas de control para obtener, proteger, organizar y revisar de forma segura todos los documentos necesarios recopilados de partes internas o externas.

La actividad de investigación debe considerar el examen de todas las pruebas aplicables.

El objetivo principal de revisar estos registros es detectar documentos críticos esenciales para la investigación.

En cuanto a la revisión a gran escala, se puede considerar el uso de herramientas tecnológicas o digitales o la contratación de proveedores de servicios o asesores externos.

NOTA Consulte [A.7.6.1](#) como orientación.

8.8.2 Recopilación, conservación, análisis y revisión de datos electrónicos

El equipo de investigación debe trabajar con el departamento de tecnología de la información o un proveedor de servicios externo cuando se requiera el análisis de cualquier evidencia electrónica para identificar, preservar y analizar datos electrónicos. Existen plataformas tecnológicas y herramientas de búsqueda/e-Discovery que pueden ayudar en la revisión de datos digitales y gestionar el flujo de trabajo de revisión de datos digitales. Los investigadores deben considerar el uso de tecnología y expertos en la materia para ayudar en la recuperación y revisión de datos electrónicos.

El equipo de investigación y el departamento de tecnología de la información o el proveedor de servicios externo deben implementar medidas adecuadas para proteger todos los datos electrónicos capturados.

El personal que realiza la recopilación, el análisis y la revisión de datos electrónicos debe tener la competencia genérica descrita en ISO/IEC 27037:2012.

NOTA Consulte [A.7.6.2](#) como orientación.

8.9 Entrevistas

8.9.1 Preparativos

Antes de realizar la(s) entrevista(s), un equipo de investigación debe hacer lo siguiente:

- Elaborar una lista inicial de las personas a entrevistar.
- Prepare un plan de entrevista que incluya un resumen de las áreas temáticas, preguntas si se considera necesario y documentos, correos electrónicos u otros materiales que se utilizarán durante la entrevista, y también decida un cronograma para el momento y la secuencia de las entrevistas. Las entrevistas deben programarse de manera que se evite que los entrevistados alteren las preguntas y respuestas de la entrevista. El plan de entrevista debe considerar los roles de los entrevistadores y las posibles respuestas del entrevistado.
- Adoptar técnicas de entrevista adecuadas.
- Realizar entrevistas utilizando técnicas apropiadas en las que los entrevistadores deben tener suficiente competencia.
- Evaluar la cultura y el ecosistema local antes de determinar la composición del equipo para una entrevista.

NOTA 1 En ciertas geografías, se puede recomendar que si la conversación es con una mujer, sería apropiado que el equipo de investigación incluya a una mujer en la sala de discusión.

- Revisar y compilar los documentos relevantes, según corresponda.
- Tomar medidas para realizar las entrevistas en un entorno libre de interferencias externas y perturbación y que pueda garantizar la confidencialidad.

NOTA 2 Véase [A.7.7.1](#) como orientación.

8.9.2 Realización de una entrevista

Se deben tomar medidas para garantizar que una entrevista, particularmente con un sujeto de una investigación, sea presenciada cuando sea apropiado. Esto puede implicar tener dos entrevistadores o un entrevistador y una persona que tome notas, o grabar la entrevista de otro modo, cuando sea apropiado y permisible. Se debe tener cuidado de garantizar que haya un número proporcional de entrevistadores presentes para evitar ser opresivos. Los entrevistadores deben considerar el idioma en el que se realizará la entrevista. Se deben hacer arreglos para la traducción si los entrevistadores no hablan el idioma que entiende el entrevistado.

El entrevistador debe, como método de investigación, aclarar con el entrevistado cualquier información incoherente o contradictoria.

Al concluir la entrevista, el entrevistador debe buscar que el entrevistado reconozca que la declaración documentada es verdadera y precisa a su leal saber y entender y preguntarle si tiene algo más que agregar o aclarar.

Se debe llevar un registro preciso de la entrevista. Los entrevistadores deben seguir políticas y procedimientos para grabar entrevistas y tener en cuenta las leyes locales. Los entrevistados podrán firmar un acta de la entrevista cuando sea apropiado y permitido.

Mientras realiza la entrevista, el entrevistador debe:

- prestar atención a las interacciones con el entrevistado;
- ser profesional y respetuoso con el entrevistado;

ISO/TS 37008:2023(E)

- ejercer una buena capacidad de escucha;
- proporcionar información precisa y correcta.

NOTA Consulte [A.7.7.2](#) como orientación.

8.9.3 Mantener registros de una entrevista

Una entrevista debe documentarse adecuada y adecuadamente, y los resultados deben almacenarse de forma segura y mantenerse confidenciales. Cada entrevista documentada podrá comunicarse por escrito al entrevistado. Los registros de las entrevistas deben conservarse de acuerdo con la política de retención de datos/registros de la organización.

NOTA Consulte [A.7.7.3](#) como orientación.

8.10 Proceso de finalización

Una investigación no debe considerarse sustancialmente completa a menos que logre lo siguiente:

- el equipo de investigación está preparado para formular conclusiones respaldadas por pruebas, y estas conclusiones son suficientes para que el órgano rector y/o la dirección tomen una decisión respecto del incidente de incumplimiento;
- el equipo de investigación puede rendir cuentas plenamente del producto de su trabajo a sus electores;
- el resultado de la investigación proporciona una base suficiente para iniciar acciones correctivas y reparadoras.

NOTA Consulte [A.7.8](#) como orientación.

8.11 Informe de investigación

Los resultados de la investigación deben registrarse por escrito. Para las investigaciones en las que se contempla un litigio y/o si es necesaria la divulgación a los reguladores (por ejemplo, el sector regulado), se debe obtener asesoramiento jurídico sobre el tratamiento (confidencial) de los informes y documentos de la investigación.

Los registros de la investigación (que incluyen registros de las entrevistas) y los informes finales de la investigación deben comunicarse de manera objetiva y precisa.

El equipo de investigación debe reunir y registrar los documentos de trabajo para respaldar el informe.

El informe de investigación deberá realizarse de acuerdo con la evidencia documental, sonora, visual y oral.

El informe de investigación debe contener una explicación completa de los hechos relevantes, las limitaciones y limitaciones encontradas y limitarse al alcance de la investigación.

El equipo de investigación debe conocer todas las leyes aplicables y seguir la política de retención de la organización en relación con la preservación de todos los registros y resultados. El equipo de investigación debe garantizar la seguridad de los datos para que no se utilicen indebidamente para otros fines y estén adecuadamente protegidos (por ejemplo, contra la pérdida de confidencialidad, el uso indebido o la pérdida de integridad).

NOTA Consulte [A.7.9](#) como orientación.

9 Posibles medidas correctivas o mejoras

9.1 Propuesta de medidas correctoras y mejoras

El equipo de investigación puede, sujeto a los requisitos de la organización, proponer medidas correctivas apropiadas que se implementarán en función de los resultados de la investigación para minimizar el impacto de las violaciones y mejorar los controles internos del programa de cumplimiento de la organización. Causa principal

Se deben utilizar métodos de análisis para llegar a las medidas correctivas y mejoras más apropiadas para garantizar que las causas fundamentales se aborden de manera adecuada, suficiente y efectiva.

9.2 Medidas correctivas provisionales

A medida que avanza la investigación, el equipo de investigación puede resaltar brechas de cumplimiento, violaciones de la ley y hacer recomendaciones al órgano rector, la alta dirección o la función de cumplimiento para tomar medidas correctivas urgentes.

El equipo de investigación debe informar a la función de cumplimiento, si así lo solicita, para ayudar a desarrollar un plan provisional sobre medidas provisionales. El plan debe establecer claramente las brechas o vulnerabilidades de cumplimiento y los objetivos que estas medidas pretenden alcanzar.

9.3 Un plan final para medidas correctivas posteriores a la investigación

La función de la organización asignada según las políticas o procedimientos correspondientes debe diseñar un plan de remediación final con base en el informe de investigación.

Las medidas correctivas posteriores a la investigación deben dividirse en pasos específicos con las tareas correspondientes asignadas a una persona responsable para su implementación adecuada y oportuna.

La función de cumplimiento debe realizar una evaluación exhaustiva del plan para garantizar su eficacia y practicidad.

9.4 Proporcionalidad de las medidas de remediación y mejora

Al formular el plan de remediación final, la función de la organización asignada de acuerdo con las políticas o procedimientos correspondientes debe considerar la gravedad de las violaciones reveladas por los hallazgos del informe de investigación. Luego debe considerar si se debe ajustar el programa de cumplimiento de la organización existente creando políticas o procedimientos nuevos o modificando los existentes, fortaleciendo o modificando el monitoreo del cumplimiento o brindando capacitación adicional en materia de cumplimiento.

9.5 Monitoreo y aplicación de medidas correctivas

La implementación de las medidas correctivas debe ser monitoreada y aplicada para garantizar su efectividad por parte de la función apropiada dentro de la organización o designada externamente.

La organización debe revisar el programa de cumplimiento para determinar si es necesario revisarlo y ajustarlo a la luz del plan de remediación.

NOTA Consulte [la Cláusula A.8](#) como orientación.

10 Interacción con las partes interesadas

10.1 Generalidades

La organización y el equipo de investigación deben tener canales de comunicación efectivos con las partes interesadas.

10.2 Planificación

La organización debe identificar las partes interesadas relevantes para la comunicación. La comunicación con estas partes interesadas debe realizarse a través del equipo de investigación o directamente a través de otra función relevante (por ejemplo, gestión, funciones de cumplimiento, recursos humanos, relaciones públicas), según corresponda.

Cada interacción debe realizarse con un propósito, con mensajes y guiones previamente planificados y en alineación con los aportes del equipo de investigación y de las funciones organizacionales que tienen experiencia e interés en la interacción correspondiente.

ISO/TS 37008:2023(E)

10.3 Medidas para el proceso de comunicación

Al comunicar los hallazgos de la investigación, la organización debe buscar aportes de la investigación. equipo.

10.4 Canales de comunicación efectivos

El equipo de investigación debe hacer planes para comunicaciones efectivas con todas las partes interesadas relevantes para garantizar que las operaciones diarias de la organización y la investigación puedan continuar.

El plan de comunicación debe apuntar a abordar cuestiones importantes y minimizar cualquier impacto negativo en las operaciones. La organización debe determinar qué nivel de información tienen derecho a conocer las diferentes partes interesadas.

La función de cumplimiento debe decidir sobre medidas de acompañamiento dependiendo del resultado de una interacción determinada para llevar a cabo la investigación a medida que avanza el asunto. Las medidas típicas incluyen acciones disciplinarias preventivas, divulgaciones a las autoridades gubernamentales, modificaciones comerciales, etc. Estas medidas deben ser evaluadas profesionalmente por la organización antes de ser tomadas. Antes de decidir las medidas, la organización debe consultar con los departamentos correspondientes dentro de la organización sobre las medidas que les conciernen.

10.5 Comunicación entre el gobierno y los reguladores

El equipo de investigación debe planificar la comunicación con las autoridades gubernamentales y los reguladores sobre los temas específicos bajo investigación, si corresponde. Antes de comunicarse con ellos, la organización debe consultar a sus asesores legales internos o externos y las directrices pertinentes para asegurarse de que los intereses y derechos de la organización estén plenamente protegidos.

10.6 Autodivulgación a las autoridades

Sobre la base del progreso de la investigación, el equipo de investigación debe proporcionar la evidencia o información necesaria a la función legal y de cumplimiento de la organización para asesorar al órgano de gobierno de la organización o a la alta dirección para evaluar si la organización debe hacer una autodivulgación a las autoridades, por ejemplo, para la reducción o exoneración de responsabilidad. Los tomadores de decisiones deben considerar las pautas de divulgación proporcionadas por la autoridad gubernamental o regulatoria pertinente y las posibles consecuencias legales de la divulgación voluntaria. Para la evaluación de las consecuencias legales, la organización debería considerar buscar asesoramiento legal profesional.

NOTA Consulte [la Cláusula A.9](#) como orientación.

11 acciones disciplinarias

Sobre la base del informe final, se adoptarán medidas disciplinarias contra el personal u organizaciones en cuestión. puede ser tomado.

NOTA Consulte [la Cláusula A.10](#) como orientación.

Anexo A (informativo)

Orientación sobre el uso de este documento

A.1 Antecedentes y alcance

A.1.1 Generalidades

La orientación contenida en este anexo es sólo ilustrativa. Su propósito es indicar en algunas áreas específicas el tipo de acciones que una organización puede tomar en la gestión y realización de investigaciones. No pretende ser exhaustivo ni prescriptivo.

A.1.2 Alcance

Las acciones gubernamentales de aplicación de la ley a menudo generan la necesidad de gestionar y realizar una investigación como parte de un esfuerzo de determinación de hechos y luego decidir qué medidas correctivas deben tomarse. Estas acciones de cumplimiento pueden estar relacionadas con cuestiones tales como controles de exportaciones, cumplimiento de sanciones, lavado de dinero, antimonopolio, soborno, fraude y anticorrupción.

Las acciones civiles y los incidentes de denunciantes también pueden ser motivo de investigaciones internas para que las organizaciones interesadas puedan descubrir qué desencadenó las acciones e incidentes y luego implementar medidas apropiadas para reducir las responsabilidades y evitar que vuelvan a ocurrir.

A.2 Referencias normativas

Las referencias normativas se relacionan con los términos y definiciones que se aplican a este documento. Los usuarios pueden consultarlos y la Bibliografía para obtener otra información y Normas Internacionales que sean relevantes para las investigaciones internas.

A.3 Principios

A.3.1 Independiente

Una investigación interna debe ser un proceso sistemático, independiente y documentado para hechos identificados y una evaluación objetiva, con la expectativa de determinar si se ha producido, está ocurriendo o es probable que se produzca alguna irregularidad y en qué medida. Para garantizar el principio de independencia, objetividad e imparcialidad de la investigación, el equipo de investigación debe actuar sin preferencias personales y sin conexión o relación con la persona sujeta a una investigación, el denunciante y otras partes interesadas. Debe haber descripciones de trabajo bien documentadas, autoridad y cualquier forma de autodeclaración para las funciones de investigación y evitar posibles conflictos de intereses y prejuicios.

El investigador debe tener autoridad para realizar la investigación y puede recomendar acciones correctivas o correctivas apropiadas y facilitar la toma de decisiones. La investigación no debe tratarse como una represalia contra el denunciante, el testigo y las partes interesadas, sino como un proceso de determinación de los hechos.

ISO/TS 37008:2023(E)

A.3.2 Competente y profesional

Un investigador debe tener conocimientos y habilidades generales o haber recibido capacitación e instrucción específicas para realizar una investigación. El investigador deberá haber adquirido conocimientos y habilidades en principios, procesos y metodologías de investigación. El investigador debería poder:

- preparar, realizar, informar y cerrar una investigación;
- comprender los tipos de riesgos y oportunidades asociados con la operación comercial de la organización;
- verificar y confirmar la relevancia y exactitud de la información recopilada;
- se relacionan con las leyes estatutarias y los requisitos reglamentarios aplicables.

La evidencia de conocimientos y habilidades puede demostrarse mediante la experiencia en el trabajo o proyecto, certificados, antecedentes educativos y capacitación, incluido el desarrollo profesional continuo (CPD) y la educación profesional continua (CPE).

Un investigador debe actuar profesionalmente, respetando y siguiendo los principios, código de conducta, políticas y procedimientos de la organización. El investigador debe demostrar credibilidad y confiabilidad siendo coherente en una investigación.

El investigador debe demostrar su sentido de responsabilidad durante la investigación siendo cortés y afectuoso.

A.3.3 Objetivo e imparcial

Un investigador no debe prometer anonimato ni ninguna otra cosa a cambio de cooperación. Se debe notificar a la persona sujeta a una investigación sobre cualquier política organizacional que requiera su participación, pero el investigador no debe ofrecer ninguna evaluación de responsabilidad legal, ninguna descripción de las protecciones aplicables a los “denunciantes” ni nada parecido a asesoramiento legal. El equipo de investigación no debe iniciar ninguna acción que pueda ir en detrimento de los objetivos de la dirección o en contra de las políticas de la organización.

Si la persona sujeta a una investigación solicita representación legal, la organización debe conocer todas las leyes y prácticas aplicables y no debe obstruir ni perjudicar injustamente a la persona que realiza la solicitud.

Si corresponde, un investigador de una organización debe notificar a la persona sujeta a la investigación que el investigador representa a la organización y no a la persona bajo la investigación.

El privilegio abogado-cliente (si corresponde) pertenece a la organización, no a la persona en cuestión. La organización puede renunciar al privilegio legal a su propia discreción, si está permitido.

A.3.4 Jurídico y lícito

Se debe realizar una investigación teniendo en cuenta las leyes y regulaciones. La decisión de realizar una investigación no constituye en sí misma una acusación sin presunción de culpabilidad y debe tratarse como un proceso neutral de determinación de los hechos.

Se debe informar a los sujetos identificados como presuntos infractores en la investigación de que tienen el deber de cooperar con el investigador, siempre que dicha cooperación no les exija simplemente admitir su culpabilidad. Se debe dar al sujeto(s) el derecho a responder según sea necesario y la opción de recibir asistencia. Los sujetos no deben interferir con la investigación. Las pruebas no deben retenerse, destruirse ni alterarse, y todas las partes involucradas en la investigación interna no deben ser influenciadas, instruidas, amenazadas o intimidadas.

Antes, durante y después de la investigación, no debe haber ningún acoso, restricción de movimiento o violación de la privacidad contra ninguna de las partes involucradas en la investigación interna.

El resultado de la investigación puede llevar a la conclusión del informe de investigación de que no se ha cometido una acción o inacción indebida o poco ética, según sea el caso.

A.4 Apoyo a las investigaciones internas

A.4.1 Recursos

Los recursos pueden incluir, entre otros, personal, asignación financiera y otras funciones organizativas, como auditoría interna, tecnología de la información, soluciones de seguridad, experiencia jurídica, desarrollo y capacitación profesional, y la función de cumplimiento. Estos recursos pueden proporcionarse interna o externamente. Una descripción más detallada de los recursos mencionados anteriormente es la siguiente:

- Personal (recursos humanos): personal suficiente y competente para dedicar suficiente tiempo a sus responsabilidades funcionales relevantes para que la investigación interna pueda funcionar eficazmente. Esto incluye asignar suficientes recursos humanos (ya sean internos o externos) a la investigación.
- Asignación financiera (recursos financieros): se pone a disposición presupuesto suficiente, también para la función de investigación interna, de modo que la investigación interna pueda funcionar eficazmente.
- Función organizativa (recursos físicos): se ponen a disposición los recursos físicos necesarios, también para la función de investigación interna, de modo que la investigación interna pueda funcionar eficazmente.

Los recursos se pueden subcontratar a abogados, auditores externos, expertos en contabilidad forense y digital, investigadores, expertos en comunicación y otros cuando sea necesario.

A.4.2 Liderazgo y compromiso

El órgano de gobierno y la alta dirección de la organización deben garantizar que la investigación interna se lleve a cabo de manera independiente, objetiva, imparcial, responsable y confidencial, sin ninguna interferencia de la alta dirección.

Debe haber cooperación entre la dirección, el equipo de investigación, los denunciantes, los testigos, los sujetos y otras partes interesadas, y se debe brindar apoyo siempre que sea necesario y cuando se considere necesario ayudar en la investigación.

Ninguna persona debe quedar sin ser escuchada, y el sujeto implicado siempre tiene derecho a beneficiarse de las reglas de la justicia natural para ser informado de las acusaciones concretas, ser oído y defenderse antes de que se adopte cualquier medida disciplinaria. De manera similar, no debería haber ninguna aplicación selectiva de las políticas de investigación.

Se debe otorgar protección y apoyo incluso si la investigación revela que la denuncia se equivocó inadvertidamente o que la acusación no está fundamentada.

A.5 Establecimiento de una política o procedimiento de investigación

Este documento proporciona orientación sobre cómo la organización debe establecer una política y un procedimiento de investigación que tenga en cuenta varios factores, incluidas las leyes aplicables, las obligaciones legales, el contexto del negocio, el tamaño de una organización, los procesos de investigación, la estructura de informes, la protección de las partes que plantean preocupaciones y responsabilidades potenciales que la organización puede enfrentar. Las investigaciones internas pueden causar directa o indirectamente riesgos legales si no se gestionan adecuadamente.

Se debe buscar opinión legal cuando existan implicaciones legales. Esto es especialmente cierto cuando se identifica información sensible o privilegiada en el curso de la investigación. También se debe buscar opinión jurídica sobre si existe una obligación reglamentaria o estatutaria de denunciar ciertos delitos penales (incluidas pérdidas financieras potenciales o reales en la medida en que se cuantifiquen) que se identifiquen en el curso de la investigación. Todas las investigaciones deben realizarse partiendo del supuesto de que el caso terminará en un proceso judicial y, por tanto, los procedimientos de investigación deben poder resistir el escrutinio del tribunal.

A.6 Medidas de seguridad y protección

A.6.1 Preservar y asegurar la evidencia

Deben existir medidas razonables para evitar la eliminación, destrucción, alteración, transferencia u ocultación deliberada o involuntaria de cualquiera de las pruebas (que incluyen pruebas físicas, digitales o testimoniales) o información útil para la investigación. Los testimonios de los testigos también son un tipo importante de evidencia. La organización puede incluir políticas internas en los procesos, como prohibir las renunciaciones de los empleados bajo investigación y obligar a todo el personal relevante a proporcionar y proteger información probatoria. Una de las formas de preservar la evidencia puede ser imponer un período mínimo de retención para las computadoras portátiles de la empresa utilizadas por personal previamente identificado en puestos sensibles después de que el personal abandone la organización. Dichas computadoras portátiles se mantendrán bajo custodia segura para preservar las pruebas forenses en caso de que se inicien investigaciones contra este personal.

También es importante evitar que la información adquirida en el curso de la investigación se filtre a personas no autorizadas, incluida la persona investigada. Una opción para mitigar el riesgo de pérdida de evidencia es implementar una política para asegurar la evidencia lo antes posible. Puede suceder que una persona sujeta a una investigación coloque un dispositivo de escuchas telefónicas o de grabación secreta o un teléfono móvil en funcionamiento en la oficina, sala de conferencias y otras salas para recopilar información relacionada con la investigación. Por lo tanto, la organización debe tener una política para comunicar la necesidad de confidencialidad a todas las partes involucradas durante la investigación (por ejemplo, testigos, entrevistados), por ejemplo:

- proporcionar tutoriales sobre aspectos de seguridad para los empleados en puestos clave y establecer un sentido de anti-intervención a la línea telefónica;
- controlar factores clave como el número de personas que entran y salen de un espacio de investigación, el control de acceso, el seguimiento de entradas y salidas y la implementación estricta del sistema de registro de visitantes;
- emplear expertos especializados y utilizar equipos profesionales para llevar a cabo actividades de lucha regulares y/o ad hoc. controles de escuchas telefónicas en áreas clave;
- utilizar bolsas antiescuchas telefónicas para envolver el(los) teléfono(s) móvil(s) del sujeto de la investigación, así como investigadores;
- colocar equipo contra escuchas telefónicas en la sala de investigación donde se lleva a cabo una investigación.

A.6.2 Protección y apoyo al personal involucrado en las investigaciones

Los testigos y los investigadores son importantes para la investigación y, por lo tanto, las organizaciones deben considerar cómo proteger razonablemente a los testigos y a los investigadores de cualquier forma de amenaza, promesa, incentivo u opresión. Proporcionar una protección razonable de la privacidad de la identidad de los testigos, mantener la confidencialidad de la información proporcionada por los testigos y proporcionar un entorno cómodo y propicio para que los testigos proporcionen la información requerida. Por ejemplo, la entrevista debe realizarse en un entorno confidencial y seguro, fuera de la vista del público y de interferencia externa.

A.6.3 Antirrepresalias

También se debe garantizar a los testigos y denunciantes que no habrá represalias si se plantean inquietudes o si la información proporcionada es de buena voluntad y sin malicia. Además, las personas que (o permitan que otros tomen) represalias deben estar sujetas a medidas disciplinarias, teniendo en cuenta las leyes locales. Las medidas de protección y el apoyo brindado a los testigos y denunciantes formarán parte de la cultura que la organización debe tratar de fomentar. Una protección y un apoyo débiles, a largo plazo, pueden dar lugar a una falta de cooperación por parte de los empleados por temor a represalias o repercusiones.

A.7 Proceso de investigación

A.7.1 Designación del equipo de investigación

Un equipo de investigación puede incluir lo siguiente:

- investigador profesional capacitado para conducir un caso complejo desde su inicio hasta su conclusión;
- personal de seguridad a quien a menudo se le asigna el trabajo de campo, por ejemplo entrevistando a testigos externos y obtener registros públicos y otros documentos de terceros;
- auditor que pueda revisar la evidencia documental interna, programar pérdidas y brindar asistencia en áreas técnicas de las operaciones de la organización;
- asesor jurídico que pueda proporcionar asesoramiento jurídico a la investigación, en la medida en que sean aspectos jurídicos preocupado;
- personal de recursos humanos y asesores legales a quienes se puede consultar para garantizar que la ley que rige la no se violan los derechos de los empleados en el lugar de trabajo;
- representante de la dirección que pueda proporcionar cualquier tipo de asistencia;
- consultor externo independiente.

Se pueden establecer líneas de notificación (directas o de puntos) para que el resultado de la investigación pueda informarse a la persona autorizada.

A.7.2 Evaluación preliminar

Antes de realizar la investigación, el investigador puede realizar la siguiente investigación preliminar no invasiva:

- ponerse en contacto con el denunciante/informante/denunciante;
- revisar toda la información manifiesta relevante;
- identificar la estructura empresarial presente en el caso;
- identificar a los principales actores;
- identificar el entorno de trabajo;
- identificar el entorno cultural;
- identificar problemas técnicos;
- identificar las leyes, reglamentos y normas aplicables;
- revisar la necesidad de involucrar a abogados externos;
- revisar la necesidad de informar al litigio sobre aspectos de la investigación.

Dependiendo del resultado de la investigación preliminar, se toma la decisión de cerrar la investigación de acuerdo con las funciones organizativas apropiadas.

A.7.3 Planificación de la investigación

Los investigadores pueden remitir asuntos para recibir asesoramiento legal cuando exista una preocupación por el privilegio profesional legal en la jurisdicción. Cuando no existe una consideración de privilegio profesional legal, pero el asunto tiene interés legal, el investigador debe considerar las actualizaciones relevantes del progreso del caso para la parte interesada legal correspondiente en una forma acordada.

ISO/TS 37008:2023(E)

A.7.4 Mantener la confidencialidad

El anonimato tiene como objetivo proteger la identidad de las personas involucradas en la investigación. Puede aplicarse a la(s) persona(s) que han informado del asunto (por ejemplo, denunciante), testigos y/o el(los) sujeto(s) de la investigación.

Se puede asignar un nombre en clave al caso bajo investigación para anonimizar la investigación. También se puede asignar un nombre en clave al sujeto de la investigación para anonimizar a la persona en cuestión.

La organización puede incorporar cualquier requisito de privacidad de datos relevante en las políticas y procedimientos de investigación. Si corresponde, las partes interesadas a las que se les informará al inicio de la investigación pueden ser la función legal o de cumplimiento y/o la persona a cargo del sector o región relevante si esto se puede hacer sin crear ningún conflicto de intereses.

A.7.5 Aviso de precaución por escrito

El investigador principal debe enviar por correo electrónico el aviso de confidencialidad al denunciante o a la persona que proporcionó la información que dio lugar a una investigación, además de las personas a las que el investigador principal decida informar.

Se recomienda proporcionar un aviso de precaución por escrito en relación con:

- responsabilidades relacionadas con violaciones de confidencialidad, incluidas, entre otras, amonestación, sanciones administrativas, terminación del empleo o responsabilidad penal;
- la importancia de la no divulgación, incluida la garantía de que se puede llevar a cabo una investigación ininterrumpida.

A.7.6 Evidencia

A.7.6.1 Recopilación y revisión de documentos

A.7.6.1.1 Almacenamiento de documentos

Los documentos deben almacenarse en un lugar seguro y donde el acceso esté restringido únicamente a los investigadores.

El acceso a los documentos electrónicos debe restringirse únicamente a las partes pertinentes.

Ver otras Normas Internacionales como ISO/IEC 27001.

A.7.6.1.2 Limitación de documentos

Si se lleva a cabo una revisión de documentos con cantidades voluminosas de datos, el equipo de investigación debe reducir metódicamente la cantidad de documentos bajo revisión. Si es necesario, los investigadores deben desarrollar (una serie de) términos clave, rango de fechas o criterios para que el proceso sea más manejable. Los investigadores también deben considerar métodos para identificar información crítica y documentos con información crítica.

Es posible que los investigadores tengan que revisar ciertos documentos para refinar y analizar la información.

A.7.6.1.3 Protocolo de revisión

Cuando un equipo de investigación inicia el proceso de revisión, debe desarrollar un protocolo de revisión para aprovechar al máximo los documentos, marcar los documentos como relevantes para temas particulares bajo investigación y categorizar los documentos recopilados en grupos para su revisión. Es posible que se requiera que el protocolo de revisión se actualice o edite durante el curso de la investigación con las aprobaciones necesarias de la gerencia.

A.7.6.1.4 Control de calidad

Una vez marcados todos los documentos potencialmente importantes en la primera ronda de revisión, investigadores de mayor nivel y experiencia (internos o externos), si es necesario, pueden realizar una segunda ronda de revisión para control de calidad. Estos investigadores superiores deberían encontrar formas de hacer que la revisión sea más eficiente identificando documentos irrelevantes que puedan descartarse. Los revisores de documentos siempre deben contar con una persona técnica a quien consultar sobre cuestiones técnicas y sustantivas.

A.7.6.2 Recolección, preservación, análisis y revisión de datos electrónicos

A.7.6.2.1 Recuperación de dispositivos electrónicos

Un investigador debe trabajar con el departamento de tecnología de la información o un proveedor de servicios externo para comprender y decidir cómo se almacenan, recuperan y analizan los datos electrónicos, siendo consciente de no dejar huellas digitales.

A.7.6.2.2 Planificación de la recuperación y el análisis

Nadie excepto el investigador principal puede decidir si es necesario recuperar un dispositivo electrónico y cómo recuperarlo. El equipo de investigación debe trabajar en estrecha colaboración con el departamento de tecnología de la información para recuperar las computadoras, teléfonos móviles y algunos otros dispositivos electrónicos del trabajo (que contienen los datos electrónicos a revisar). El investigador principal debe trabajar con el departamento de tecnología de la información para planificar y llevar a cabo el proceso de recuperación, a menos que el departamento de tecnología de la información se encuentre en una situación de conflicto de intereses.

El equipo de investigación debe mantener cierto grado de flexibilidad en este proceso. Al iniciar una investigación, es necesario recuperar la computadora portátil del sujeto para lograr un mejor resultado de la investigación. En casos de emergencia, el equipo de investigación, con la ayuda del departamento de tecnología de la información, debe recuperar inmediatamente las computadoras portátiles, teléfonos móviles y algunos otros dispositivos electrónicos (que contienen los datos electrónicos a revisar) de las personas en cuestión.

Si la recopilación de datos (es decir, imágenes forenses de discos de portátiles, servidores, móviles, etc.) se va a realizar de forma discreta, el equipo de investigación debe garantizar que la adquisición y gestión de datos se alineen con las políticas de tecnología de la información de la organización.

A.7.6.2.3 Servicio de terceros

Se puede contratar a un proveedor externo de servicios forenses digitales para realizar la recuperación y el análisis forense de los datos o documentos recuperados de las computadoras portátiles, teléfonos móviles y algunos otros dispositivos electrónicos de las personas en cuestión.

A.7.6.2.4 Recopilación de datos forenses

Un equipo de investigación debe decidir cómo realizar el análisis de datos forenses de la siguiente manera:

- Recopilación remota de datos: si el custodio objetivo todavía está empleado, el equipo de investigación puede realizar una recopilación remota de datos de la computadora de trabajo del custodio y considerar crear una imagen forense completa a través de la red de la organización sin previo aviso del custodio.
- Recopilación de datos en vivo: cuando es necesario adquirir datos en vivo de dispositivos que aún están en funcionamiento. La recopilación en vivo de datos volátiles en la memoria de acceso aleatorio (RAM) puede permitir la recuperación de información valiosa como el estado de la red, aplicaciones descifradas y contraseñas.
- Recopilación de datos fuera de línea: el equipo de investigación también puede aplicar la recopilación fuera de línea para realizar imágenes completas utilizando herramientas forenses estándar de la industria y documentación exhaustiva para mantener los procedimientos de la cadena de custodia.
- Recopilación de datos de correo electrónico: el equipo de investigación, con asistencia de expertos, puede recopilar de la organización una copia de los datos de correo electrónico del custodio.

ISO/TS 37008:2023(E)

- Análisis de datos: el equipo realizará un análisis forense de las imágenes forenses recopiladas. Los resultados del análisis se proporcionarán al equipo de investigación o al asesor externo para su revisión.

A.7.6.2.5 Análisis forense

El análisis forense se puede realizar teniendo en cuenta lo siguiente:

- Historial de Internet: los sitios web que el custodio ha visitado recientemente, incluidas las actividades asociadas con cualquier servicio basado en la nube.
- Lista de acceso a archivos/modificados/creados: una lista de archivos a los que se ha accedido/modificado/creado recientemente.
- Historial USB: una lista de archivos que se han copiado a dispositivos de almacenamiento externos.
- Historial del servidor en la nube: una lista de documentos o actividades de los usuarios en los servidores en la nube.
- Recuperación de eliminación: una lista de archivos que han sido eliminados pero recuperados por los expertos forenses del equipo de investigación.
- Registros de mensajes instantáneos: el equipo también puede proporcionarlos al propio equipo de investigación o a abogados externos. con los registros de mensajes instantáneos descifrados de la computadora de destino.
- Procesamiento de datos: el equipo de investigación puede, generalmente a través de un experto forense externo, emplear motores de procesamiento para procesar los datos de hojas de cálculo y correos electrónicos extraídos, discerniendo los datos extraídos a nivel de elemento exactamente sobre qué datos están contenidos en el universo presentado. registrar todos los metadatos a nivel de elemento tal como existían antes del procesamiento, y permitir una reducción defendible de los datos seleccionando solo los elementos apropiados para avanzar en la revisión.
- Revisión de pruebas: los datos se alojan en una plataforma de revisión basada en la web en la que el equipo de investigación o abogados externos pueden revisar los documentos de forma sinérgica y sincrónica.
- Informes: el equipo de investigación proporciona un informe que resume el trabajo realizado y cómo se llevó a cabo.
- Análisis de datos: el equipo de investigación debe analizar la investigación recopilada como se mencionó anteriormente. junto con el resultado de la revisión del documento y la entrevista a la persona interesada.

A.7.7 Entrevistas

A.7.7.1 Preparativos

Las técnicas de entrevista incluyen escuchar atentamente, hacer preguntas generales, buscar la cooperación de los testigos y llegar a puntos en común.

El entrevistador debe proponer a la persona objeto de una investigación que sea asistida durante la entrevista por representantes de los trabajadores o representantes sindicales, teniendo en cuenta la legislación local.

A.7.7.2 Realización de una entrevista

La entrevista debe realizarse de la siguiente manera:

- mantener las entrevistas encaminadas y fluidas de forma lógica;
- seguir el plan o esquema de la entrevista, pero estar preparado para improvisar;
- mantener la entrevista confidencial y los recuerdos de cada testigo libres de las opiniones de los demás;
- estar preparados para afrontar la falta de cooperación de los entrevistados aplicando técnicas de persuasión e imponiendo medidas disciplinarias.

A.7.7.3 Mantener registros de una entrevista

Si se preparan notas detalladas o memorandos de entrevistas, se deben tomar medidas específicas para proteger estos documentos como productos privilegiados y de trabajo entre abogado y cliente (si corresponde).

Los entrevistadores no deben entregar notas escritas ni memorandos a ningún sujeto, testigo o su abogado.

Los entrevistadores pueden grabar una entrevista en cualquier forma (por ejemplo, audio y/o video), teniendo en cuenta la legislación local.

A.7.8 Proceso de finalización

El equipo de investigación deberá finalizar la investigación cuando pueda explicar el presunto incidente de forma coherente. De lo contrario, debe continuar la investigación hasta que no haya más información disponible o fuentes adicionales, momento en el cual debe finalizar la investigación y el equipo de investigación debe explicar las limitaciones de la información.

Como parte del proceso de finalización de la investigación, el equipo de investigación podrá:

- crear un documento de acuse de recibo que indique el resultado de la investigación:
 - alegación fundamentada;
 - alegación sin fundamento;
 - no concluyente;
- organizar los documentos de la investigación;
- colocar todos los documentos y productos del trabajo en una carpeta con un índice y separadores con pestañas si la organización requiere que las copias impresas se conserven en formato papel;
- comunicar los resultados de la investigación al órgano rector, y aprobarlos y ser pertinentes partes interesadas;
- preparar un informe/presentación que resuma la investigación;
- proponer destinatarios internos de los resultados de la investigación (por ejemplo, recursos humanos, controladores, departamentos financieros) y si deben comunicarse al denunciante o al denunciante.

El órgano de gobierno debe buscar opinión legal sobre si debe informar la (potencial) inquietud a los órganos organizativos y reguladores apropiados. Debería identificar los organismos reguladores que exigen la presentación de informes y quién realizará el informe, y debería estar preparado para cualquier posible repercusión.

A.7.9 Informe de investigación

Un informe de investigación típico suele incluir un resumen ejecutivo, antecedentes, presentación/descripción de la metodología de investigación y evidencia encontrada, análisis de la evidencia y una conclusión, y puede incluir recomendaciones (es decir, mejoras de control) si la organización lo requiere.

El resumen ejecutivo normalmente debe incluir los hallazgos, conclusiones y sugerencias clave para medidas correctivas.

La descripción de antecedentes generalmente debe incluir los departamentos o unidades involucradas, las actividades relevantes de las unidades involucradas, los empleados involucrados y las relaciones con los empleados, los hechos de antecedentes sujetos a alegación o incidente y las cuestiones fácticas que deben resolverse.

El análisis de las pruebas en el informe de investigación normalmente debe incluir reconocer las posiciones de cada parte, describir las pruebas que respaldan cada posición, evaluar los hechos, identificar los hechos relevantes, descartar los hechos irrelevantes y evaluar la credibilidad de los hechos controvertidos.

ISO/TS 37008:2023(E)

La conclusión del informe de investigación puede incluir los siguientes elementos clave:

- a) referencia a la norma de política en cuestión para que el órgano de gobierno y las partes interesadas aprobadas y relevantes tomen las decisiones correspondientes;
- b) establecer conclusiones que puedan utilizarse para alcanzar los objetivos relativos a los hechos objeto de estudio investigación;
- c) proporcionar las conclusiones, en lugar de una conclusión legal, para determinar si la inquietud o alegación está fundamentada, no fundamentada o no es concluyente.

A.8 Posibles medidas correctivas o mejoras

Un informe de investigación adecuado es una base sólida para tomar medidas correctivas. Estas acciones deben abordar las causas del incidente de incumplimiento.

Las funciones organizacionales apropiadas deben preparar un plan de remediación que considere:

- una evaluación de la suficiencia, idoneidad y eficacia de los controles internos existentes para detener el incidente de incumplimiento;
- una hoja de ruta sobre cómo mejorar los controles internos existentes.

Algunas medidas correctivas a considerar por la organización pueden ser:

- a) proporcionar capacitación especializada en cumplimiento a los empleados;
- b) mejorar los controles internos de la organización para prevenir el incidente de incumplimiento;
- c) revisar la relación contractual con terceros;
- d) someter el programa de cumplimiento y/o controles específicos a auditorías o pruebas;
- e) reestructurar las áreas y puestos involucrados en el incidente de incumplimiento.

A.9 Interacción con las partes interesadas

La identificación de coyunturas críticas para comunicarse con las partes interesadas relevantes es parte de la responsabilidad del equipo de investigación. La interacción con las partes interesadas relevantes puede ocurrir antes, durante o después de la investigación. La coyuntura precisa debe determinarse en función de los hechos materiales que se descubran en la investigación. El equipo debe ejercer su criterio profesional sobre el tema y buscar aportes del equipo de cumplimiento de la organización para maximizar el beneficio ofrecido por estos momentos críticos.

Las partes interesadas relevantes pueden ser externas e internas. Las partes interesadas externas, como autoridades, auditores financieros, proveedores y clientes, son importantes porque tienen un impacto significativo en las operaciones normales de una organización determinada. Las partes interesadas internas incluyen, entre otras, los empleados y accionistas de una organización determinada. Tienen un efecto muy directo sobre cómo se lleva a cabo la investigación. La identificación de estos sujetos de interacción debe realizarse antes de llevar a cabo la investigación. La planificación de la investigación debe minimizar el impacto en la operación diaria de la organización.

La organización debería haber establecido estándares de comunicación a aplicar y un conjunto de herramientas de comunicación sólido para una gestión exitosa de las partes interesadas. Diferentes partes interesadas requieren diferentes formas de estrategias de comunicación. Sin embargo, existen algunos puntos comunes a tener en cuenta para una comunicación óptima. La característica más importante de cualquier proceso de comunicación es escuchar/recopilar información cuidadosamente que coloque las relaciones públicas de la organización en una mejor posición. La comunicación en los diferentes niveles de una organización debe ser coherente para evitar mensajes contradictorios. También se debe mejorar y fomentar la continuidad de la interacción y comunicación con las partes interesadas relevantes para garantizar que las partes interesadas sean conscientes de los procesos de flujo de la

investigación. Además, las partes interesadas también deben pasar por un proceso de campaña de concientización para alinearse con los procedimientos existentes de una organización.

Se deben considerar los beneficios y riesgos que figuran en la [Tabla A.1](#) al momento de realizar una divulgación propia.

Tabla A.1 — Beneficios y riesgos

No.	Beneficios	Riesgos
1	Esto puede ser obligatorio.	Posteriormente, las autoridades investigan la organización de una manera más extensa y dura.
2	La cooperación activa da como resultado el aplazamiento del procesamiento de acciones y/o acuerdos.	Las partes interesadas inician acciones legales inesperadas.
3	Por la gravedad de la conducta en pregunta, es imprescindible.	Obligaciones de anticipo/indemnización de honorarios.
4	Se disuade a los posibles malhechores de seguir adelante incumplimiento.	Se incrementa el riesgo de renuncia a los privilegios que protegen las investigaciones internas.
5	Las organizaciones pueden controlar los asuntos y gestionar el alcance del daño.	Esto puede generar problemas de competencia o provocar una ruptura de las relaciones comerciales.
6	La cooperación continua permitirá a los reguladores ver la situación de la organización con simpatía.	La investigación posterior no está cubierta por el seguro.

A.10 Acciones disciplinarias

El órgano de gobierno y/o la dirección correspondiente, en consulta con el equipo de recursos humanos, debe decidir si se deben adoptar medidas disciplinarias contra las personas investigadas.

Esto depende en gran medida del tipo, entorno, circunstancias, contexto y complejidad de la organización en la que se opera en la industria:

- las organizaciones que contratan principalmente con el gobierno deben priorizar su buena fe con autoridades gubernamentales;
- algunos necesitan proteger su reputación.

El interés superior de una organización también depende de las circunstancias específicas del momento. Por ejemplo, las medidas gubernamentales de aplicación de la ley por sí solas pueden provocar daños significativos a la reputación o pérdidas comerciales. Entonces, lo mejor para la organización es limpiar su nombre rápidamente. Por tanto, se debe tener en cuenta la circunstancia específica antes de adoptar medidas disciplinarias.

Los factores adicionales que deben evaluarse para imponer acciones disciplinarias incluyen, entre otros:

- la reacción del gobierno;
- antigüedad de las personas investigadas;
- nivel de publicidad;
- los requisitos reglamentarios;
- necesidad de disuasión;
- gravedad de la conducta ilícita;
- sanción disponible;
- importe de la pérdida financiera y su impacto potencial en la organización (materialidad).

Se debe considerar un equilibrio al evaluar estos factores.

ISO/TS 37008:2023(E)

Bibliografía

- [1] ISO 19650-5:2020, Organización y digitalización de información sobre edificios y obras de ingeniería civil, incluido el modelado de información de construcción (BIM). Gestión de la información mediante el modelado de información de construcción. Parte 5: Enfoque de gestión de la información centrado en la seguridad.
- [2] ISO 31000:2018, Gestión de riesgos. Directrices
- [3] ISO 37000:2021, Gobernanza de las organizaciones. Orientación
- [4] ISO/IEC 27001, Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de gestión de seguridad de la información. Requisitos.
- [5] ISO/IEC 27037:2012, Tecnología de la información. Técnicas de seguridad. Directrices para la identificación, recopilación, adquisición y preservación de evidencia digital.

ISO/TS 37008:2023(E)